

实验单元5： 命令注入

5.1 实训说明

5.1.1 实训目的

- 1.掌握命令注入漏洞利用的常见命令。
- 2.掌握命令注入相关的危险函数。
- 3.掌握利用攻击代码获得目标主机 shell。

5.1.2 背景知识

- 1.掌握命令注入的基本原理。
- 2.掌握命令注入的分类和判断。
- 3.掌握命令注入的基本防御。

5.1.3 实习时长

2 个学时

5.2 实训环境

5.2.1 实训器材

kali linux 2024

5.2.2 网络结构



kali linux 2024 虚拟机 ()

5.3 实训内容

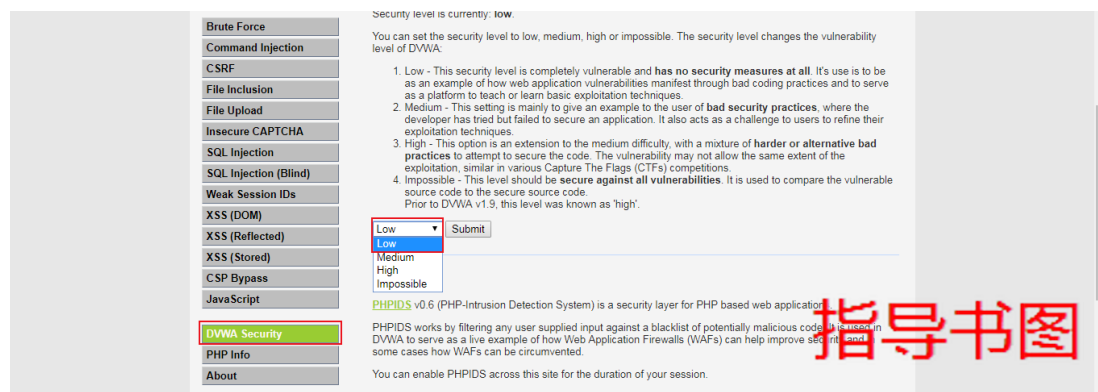
5.3.1 实训准备

打开 Apache2 和 mariadb 服务。

登录 DVWA, 在浏览器输入 <http://127.0.0.1/DVWA/login.php>, 转到 DVWA 的登录页面, 使用用户名 admin, 密码 password 进行登录。

5.3.2 命令注入-Low

1. DVWA 1.9 的代码分为四种安全级别: Low, Medium, High, Impossible。选择 Low 安全级别。



服务器端代码, 可以看到, 服务器通过判断操作系统执行不同 ping 命令, 但是对 ip 参数并未做任何的过滤, 导致了严重的命令注入漏洞。

```
<?php
if( isset( $_POST[ 'Submit' ] ) ) {
    // Get input
    $target = $_REQUEST[ 'ip' ];

    // Determine OS and execute the ping command.
    if( striistr( php_uname( 's' ), 'Windows NT' ) ) {
        // Windows
        $cmd = shell_exec( 'ping ' . $target );
    }
    else {
        // *nix
        $cmd = shell_exec( 'ping -c 4 ' . $target );
    }

    // Feedback for the end user
    echo "<pre>{$cmd}</pre>";
}

?>
```

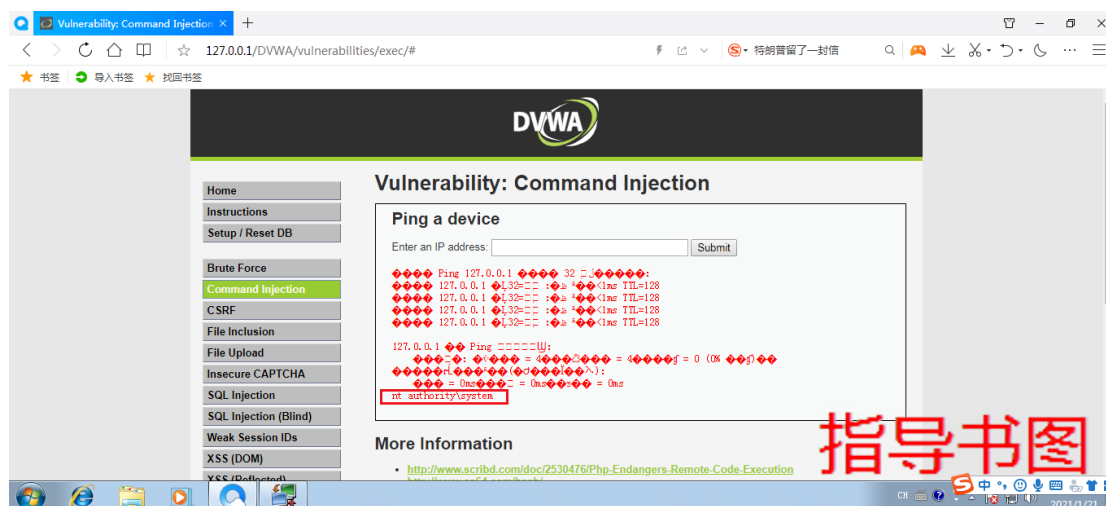
striistr(string,search,before_search)

striistr 函数搜索字符串在另一字符串中的第一次出现, 返回字符串的剩余部分 (从匹配点), 如果未找到所搜索的字符串, 则返回 FALSE。参数 string 规定被搜索的字符串, 参数 search 规定要搜索的字符串 (如果该参数是数字, 则搜索匹配该数字对应的 ASCII 值的字符), 可选参数 before_true 为布尔型, 默认为 "false", 如果设置为 "true", 函数将返回 search 参数第一次出现之前的字符串部分。

php_uname(mode)

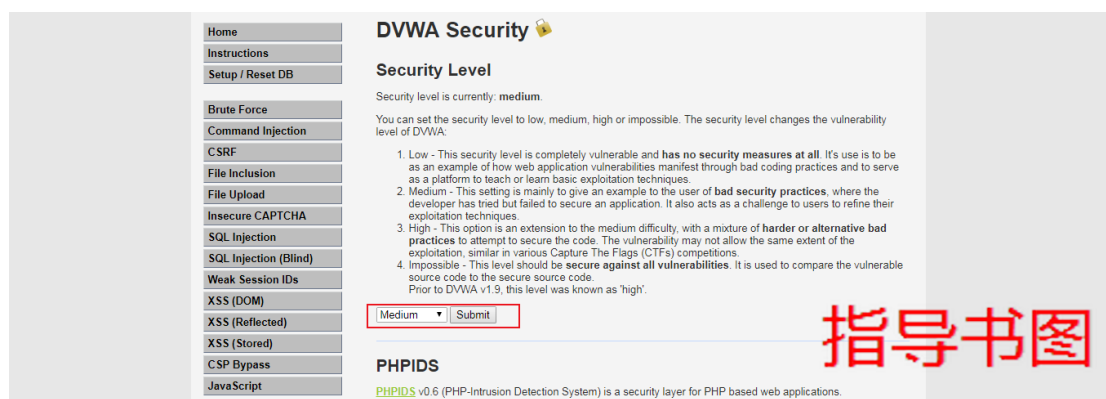
这个函数会返回运行 php 的操作系统的相关描述，参数 mode 可取值“a”（此为默认，包含序列“snrvm”里的所有模式），“s”（返回操作系统名称），“n”（返回主机名），“r”（返回版本名称），“v”（返回版本信息），“m”（返回机器类型）。

2. Windows 通过&&来执行多条命令，执行 127.0.0.1&&whoami。输出两条命令的结果。



5.3.3 命令注入-Medium

1. DVWA 1.9 的代码分为四种安全级别: Low, Medium, High, Impossible。选择 Medium 安全级别。



2. 服务器端代码，可以看到，相比 Low 级别的代码，服务器端对 ip 参数做了一定过滤，即把“&&”、“;”删除，本质上采用的是黑名单机制，因此依旧存在安全问题。

```

<?php
if( isset( $_POST[ 'Submit' ] ) ) {
    // Get input
    $target = $_REQUEST[ 'ip' ];

    // Set blacklist
    $substitutions = array(
        '&&' => ' ',
        ';' => ' ',
    );

    // Remove any of the characters in the array (blacklist).
    $target = str_replace( array_keys( $substitutions ), $substitutions, $target );

    // Determine OS and execute the ping command.
    if( stripos( php_uname( 's' ), 'Windows NT' ) ) {
        // Windows
        $cmd = shell_exec( 'ping ' . $target );
    }
    else {
        // *nix
        $cmd = shell_exec( 'ping -c 4 ' . $target );
    }

    // Feedback for the end user
    echo "<pre>{$cmd}</pre>";
}
?>

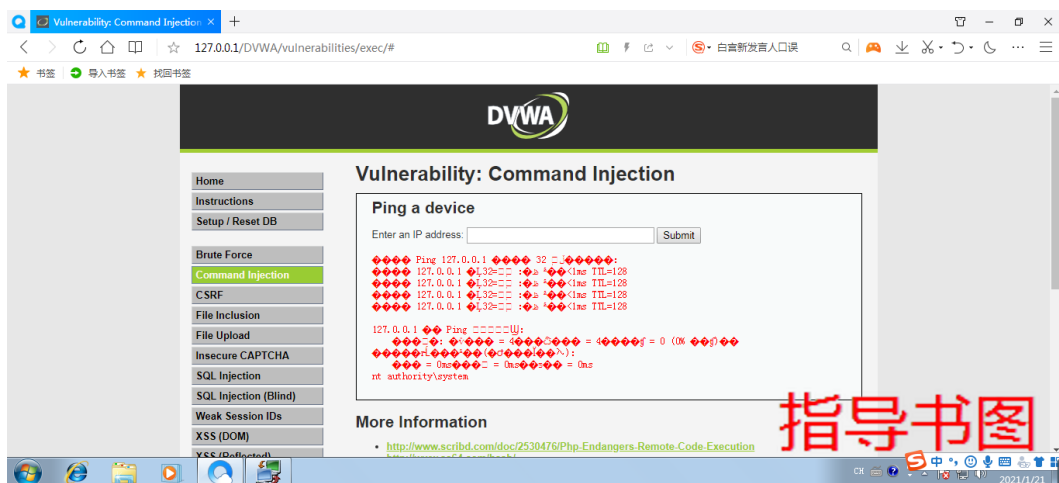
```

指导书图

3. 因为被过滤的只有“&&”与“;”，所以“&”不会受影响。执行 127.0.0.1&whoami。输出两条命令的结果。

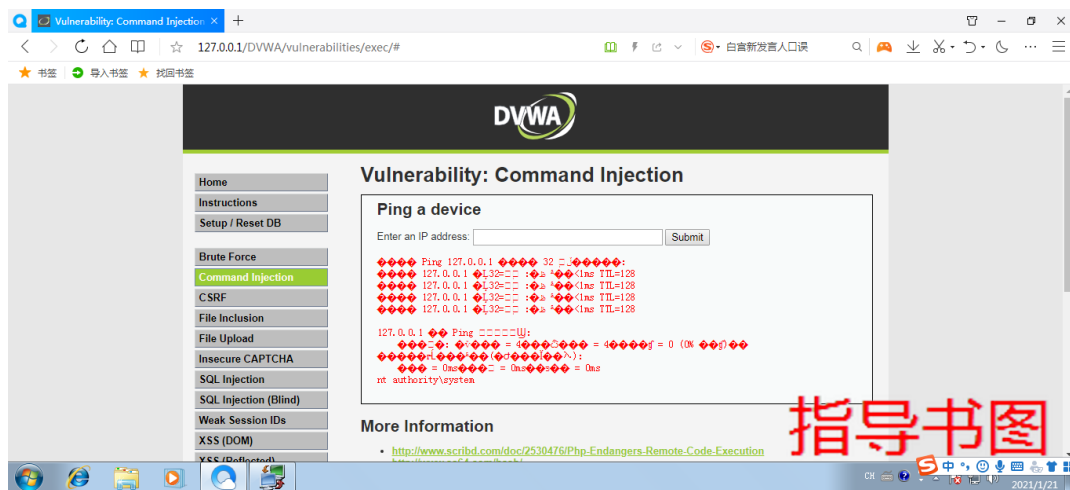
Command 1&&Command 2: 先执行 Command 1，执行成功后执行 Command 2，否则不执行 Command 2;

Command 1&Command 2: 先执行 Command 1，不管是否成功，都会执行 Command 2。



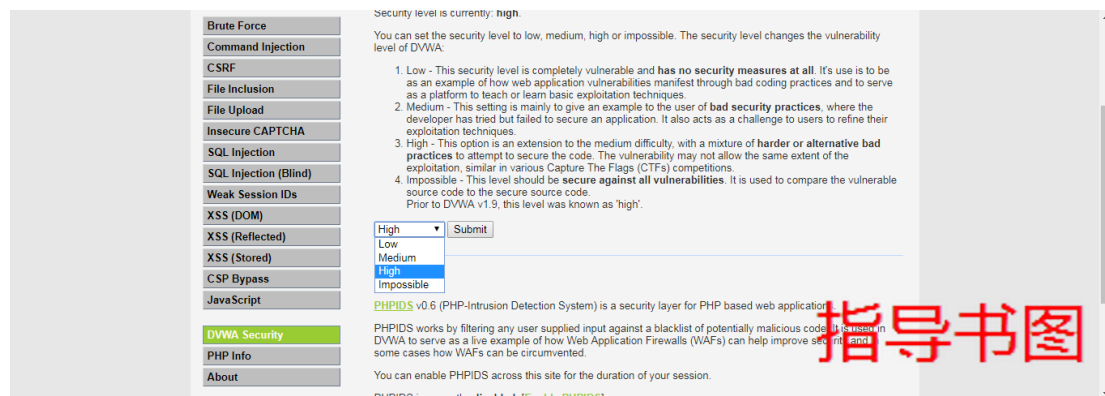
指导书图

4. 由于使用的是 str_replace 把“&&”、“;”替换为空字符，因此可以采用以下方式绕过：127.0.0.1&&ipconfig。因为“127.0.0.1&&ipconfig”中的“;”会被替换为空字符，这样一来就变成了“127.0.0.1&& ipconfig”，会成功执行。



5.3.4 命令注入-High

1. DVWA 1.9 的代码分为四种安全级别: Low, Medium, High, Impossible。选择 High 安全级别。



2. 服务器端代码, 可以看到, 相比 Medium 级别的代码, High 级别的代码进一步完善了黑名单, 但由于黑名单机制的局限性, 我们依然可以绕过。

```
if( isset( $_POST[ 'Submit' ] ) ) {
    // Get input
    $target = trim($_REQUEST[ 'ip' ] );

    // Set blacklist
    $substitutions = array(
        '&' => '',
        '.' => '',
        '|' => '',
        '-' => '',
        '$' => '',
        '(' => '',
        ')' => '',
        '"' => '',
        '\\' => ''
    );

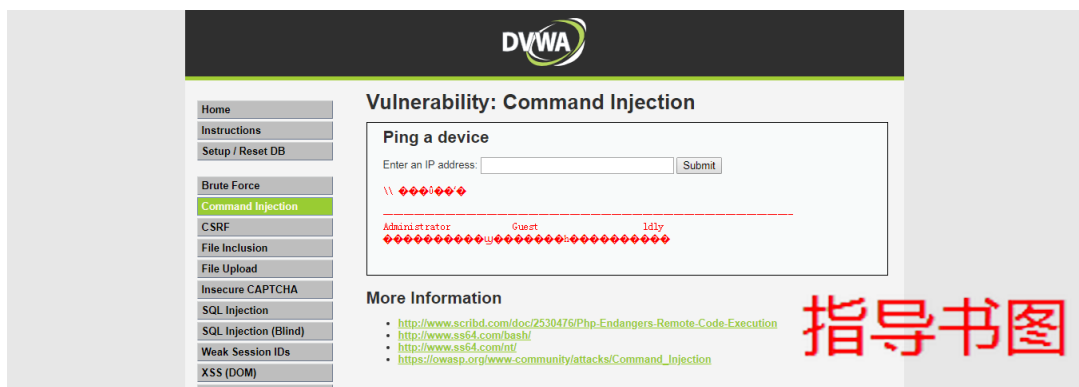
    // Remove any of the characters in the array (blacklist).
    $target = str_replace( array_keys( $substitutions ), $substitutions, $target );

    // Determine OS and execute the ping command.
    if( stripos( php_uname( 's' ), 'Windows NT' ) ) {
        // Windows
        $cmd = shell_exec( 'ping ' . $target );
    }
    else {
        // *nix
        $cmd = shell_exec( 'ping -c 4 ' . $target );
    }

    // Feedback for the end user
    echo "<pre>{$cmd}</pre>";
}
```

3. 黑名单看似过滤了所有的非法字符，但仔细观察到是把“|”替换为空字符，于是“|”成了“漏网之鱼”。执行 127.0.0.1|net user，输出两条命令的结果。

Command 1 | Command 2: “|”是管道符，表示将 Command 1 的输出作为 Command 2 的输入，并且只打印 Command 2 执行的结果。



5.4 总结与思考

5.4.1 实训总结

这部分内容是关于命令注入的操作过程，主要包括：

- 命令注入的相关函数
- 命令注入的利用方式
- 命令注入的绕过方法

5.4.2 思考题

问题 1：命令注入连接命令 127.0.0.1&&net user 的输出？

问题 2：命令注入连接命令 127.0.0.1&net user 的输出？

问题 3：命令注入连接命令 127.0.0.1||net user 的输出？

问题 4：命令注入连接命令 127.0.0.1|net user 的输出？